TP0.1 – CamTrust Bank

Lien du dépôt github : *https://github.com/Abdosrad07/Systems-and-Networks-Security*

1. Résumé pour la direction

Nous avons testé, dans un laboratoire GNS3 isolé, les échanges de plusieurs services réseau. Les observations montrent que HTTP, FTP, Telnet et SNMPv2c peuvent exposer des informations lorsqu'ils sont utilisés sans chiffrement adapté. Un observateur placé sur le chemin réseau pourrait lire des identifiants, des commandes ou des informations techniques. La priorité est de remplacer HTTP par HTTPS, FTP par SFTP/FTPS, Telnet par SSH et SNMPv2c par SNMPv3 authPriv. Les preuves présentées proviennent du laboratoire pédagogique ; elles ne constituent pas un test du réseau réel de la banque.

2. Périmètre et autorisation

Environnement	Topologie GNS3 isolée, représentant le siège, l'agence de Douala et un accès Internet simulé.
Date du test	22 octobre 2026.
Outils	Wireshark, tcpdump, curl, dig, snmpwalk, Telnet, SSH et ping.
Équipe / autorisation	Binôme ; exercice pédagogique autorisé, limité au laboratoire.
Services et objectif	Web, transfert de fichiers, administration des routeurs, supervision et protocoles réseau de base. Objectif : repérer les données observables et proposer des corrections.

Le réseau reproduit un siège et une agence de CamTrust Bank, avec un accès Internet simulé, des postes clients en DHCP et des services web, DNS et FTP. L'objectif est d'évaluer la confidentialité des données sur les protocoles observés et de produire une preuve nette à destination d'un responsable.

3. Constats

3.1. Tableau C.5 – Synthèse

Service	Protocole utilisé	Ce qui est visible en clair	Protocole sûr de remplacement	Effort estimé en entreprise
Espace agents web	HTTP	Identifiant, mot de passe, requêtes, envoyés en clair	HTTPS	Faible
Transfert de fichiers	FTP	USER, PASS, contenus transférés	SFTP / FTPS	Moyen
Administration routeur	Telnet	Login mot de passe, commandes	SSH v2	Faible
Supervision	SNMP v2c	Communauté, informations système, nom et version de l'équipement	SNMPv3 authPriv	Faible à moyen

3.2 Captures d’écran de preuve

Les captures ci-dessous sont présentées avec les mots de passe floutés afin de respecter les règles du laboratoire et de préserver la confidentialité du contexte pédagogique.

3.1. Espace web : HTTP puis HTTPS

Avant : la réponse HTTP et des métadonnées de requête sont lisibles. Après : la capture TLS montre des données applicatives chiffrées, non directement lisibles comme du texte HTTP.

```
> HTTP/1.1 200 OK\r\n
  Date: Thu, 22 Oct 2026 19:15:36 GMT\r\n
  Server: Apache/2.4.52 (Ubuntu)\r\n
  Last-Modified: Thu, 22 Oct 2026 05:48:49 GMT\r\n
  ETag: "239-65e676afccc99"\r\n
  Accept-Ranges: bytes\r\n
> Content-Length: 569\r\n
  Vary: Accept-Encoding\r\n
  Content-Type: text/html\r\n
  \r\n
  [Request in frame: 4]
  [Time since request: 633.000 microseconds]
  [Request URI: /]
  [Full request URI: http://www.camtrust.lab/]
  File Data: 569 bytes
```

Avant — HTTP : contenu lisible

```
v TLSv1.3 Record Layer: Application Data Protocol: Hypertext Transfer Protocol
    Opaque Type: Application Data (23)
    Version: TLS 1.2 (0x0303)
    Length: 281
    Encrypted Application Data [...]: 7dc9fa520315c41c573697d2fc4d32d8b1ddee5d99535170be1
    [Application Data Protocol: Hypertext Transfer Protocol]
v TLSv1.3 Record Layer: Application Data Protocol: Hypertext Transfer Protocol
    Opaque Type: Application Data (23)
    Version: TLS 1.2 (0x0303)
    Length: 69
    Encrypted Application Data: b1ed2ce33d0fc24a144125b17c0eecafdb4c7732c196733965bb866
    [Application Data Protocol: Hypertext Transfer Protocol]
```

Après — TLS : données chiffrées

HTTPS protège la confidentialité des échanges entre le navigateur et le serveur. Il faut aussi vérifier le certificat et forcer la redirection vers HTTPS.

3.2. Transfert de fichiers et administration

FTP — authentification observable

La capture FTP montre le dialogue du protocole et les commandes d’authentification. Les informations sensibles sont masquées dans l’image. FTP classique ne chiffre ni les identifiants ni le contenu transféré.

ftp

No.	Time	Source	Destination	Protocol	Lengtl	Info
4	0.034515	203.0.113.10	203.0.113.1	FTP	86	Response: 220 (vsFTPd 3.0.5)
6	0.084012	203.0.113.1	203.0.113.10	FTP	81	Request: USER agentftp
8	0.084117	203.0.113.10	203.0.113.1	FTP	100	Response: 331 Please specify the password.
9	0.139546	203.0.113.1	203.0.113.10	FTP	80	Request: PASS [redacted]
11	0.257378	203.0.113.10	203.0.113.1	FTP	89	Response: 230 Login successful.
12	0.298143	203.0.113.1	203.0.113.10	FTP	71	Request: PWD
14	0.298599	203.0.113.10	203.0.113.1	FTP	100	Response: 257 "/" is the current directory
15	0.354600	203.0.113.1	203.0.113.10	FTP	72	Request: EPSV
16	0.355379	203.0.113.10	203.0.113.1	FTP	114	Response: 229 Entering Extended Passive Mode (|||40010|)
18	0.465842	203.0.113.1	203.0.113.10	FTP	74	Request: TYPE A
19	0.465921	203.0.113.10	203.0.113.1	FTP	96	Response: 200 Switching to ASCII mode.
21	0.519165	203.0.113.1	203.0.113.10	FTP	72	Request: LIST
22	0.519665	203.0.113.10	203.0.113.1	FTP	105	Response: 150 Here comes the directory listing.
23	0.585273	203.0.113.10	203.0.113.1	FTP	90	Response: 226 Directory send OK.
26	0.656540	203.0.113.1	203.0.113.10	FTP	72	Request: QUIT
27	0.657126	203.0.113.10	203.0.113.1	FTP	80	Response: 221 Goodbye.

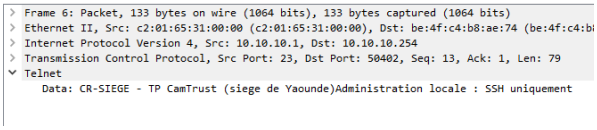
Donnée d'authentification masquée

Figure 3 — Capture FTP issue du laboratoire ; détail d’authentification masqué.

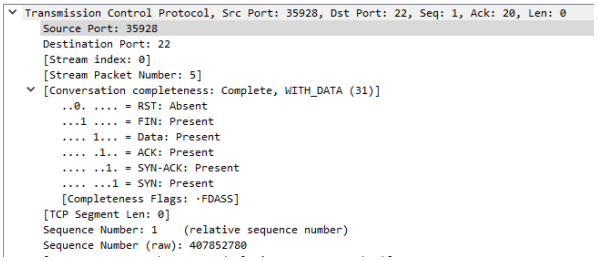
Correction : migrer vers SFTP (via SSH) ou FTPS, puis désactiver FTP classique après validation des clients et des transferts.

Telnet → SSH — administration du routeur

La preuve Telnet illustre une session d'administration non chiffrée ; la preuve SSH montre une session sur le port TCP 22. SSH protège les identifiants et commandes pendant le transport.



Avant — Telnet / données lisibles

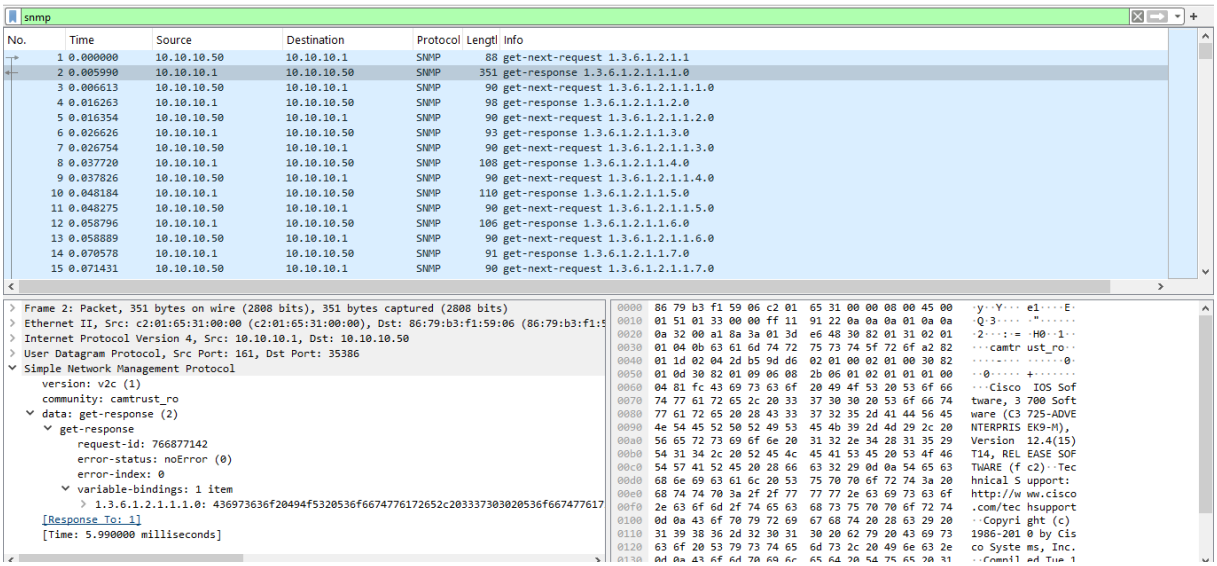


Après — session SSH / TCP 22

Mesure de validation : confirmer qu'une connexion SSH fonctionne avec le compte autorisé, puis vérifier que Telnet est désactivé. La configuration R-SIEGE fournie limite les lignes VTY à SSH.

Supervision – SNMP v2c

La communauté SNMP ainsi que les informations système de l'équipement sont visibles en clair. Cela facilite les attaques ciblées et la collecte d'informations sur la cible.



Correction : utiliser SNMPv3 en mode authPriv (authentification et confidentialité), limiter les hôtes autorisés à interroger les équipements et remplacer toute communauté de test.

Protocoles réseau de base observés

ARP	Requête diffusée puis réponse unicast ; pas d'authentification native de l'émetteur.	Risque d'usurpation sur le LAN ; activer les protections de couche 2 adaptées.
DHCP	Discover, Offer, Request et Ack visibles ; l'offre n'est pas authentifiée par défaut.	Activer DHCP snooping sur les commutateurs compatibles.
DNS	Requêtes/réponses visibles sur UDP 53 ; les noms consultés peuvent être observés.	Réduire l'exposition et sécuriser les résolveurs ; le chiffrement DNS dépend du contexte.
TCP / HTTP	La capture permet de voir la connexion jusqu'au contenu HTTP lorsqu'il n'est pas chiffré.	Sécuriser les applications avec TLS ; TCP seul ne chiffre pas les données.

4. Plan d'action priorisé

P1 — Web	HTTPS, redirection forcée, HSTS ; vérifier le certificat.	1 jour	M8 — sécurité web / TLS
P1 — Administration	SSH v2 ; désactiver Telnet et tester l'accès de secours.	0,5 jour	M3 — accès sécurisés
P1 — Fichiers	Migrer FTP vers SFTP ou FTPS ; tester les comptes et transferts.	1 à 3 jours	M3 / M8 — chiffrement applicatif
P2 — Supervision	SNMPv3 authPriv, ACL de supervision, rotation des communautés.	0,5 jour par équipement	M3 — supervision sécurisée
P2 — LAN	Activer DHCP snooping, DAI et port security selon les capacités des équipements.	2 à 3 jours	M2 — sécurité LAN / couche 2

Ordre recommandé : protéger d'abord les identifiants et les accès d'administration, ensuite la supervision, puis renforcer les protections du réseau local. Les efforts sont des estimations de planification, à confirmer selon le parc et les fenêtres de maintenance.

5. Annexes — configurations finales fournies

Les extraits ci-dessous reprennent les configurations présentes dans le document source. Ils sont reproduits comme annexes du TP et ne valent pas validation indépendante de la configuration complète.

5.1. R-SIEGE — routeur Cisco

```
hostname R-SIEGE
interface GigabitEthernet0/0
 ip address 10.10.10.1 255.255.255.0
 no shutdown
interface GigabitEthernet0/1
 ip address 198.51.100.2 255.255.255.252
 no shutdown
interface GigabitEthernet0/2
 ip address 172.16.12.1 255.255.255.252
 no shutdown
ip route 0.0.0.0 0.0.0.0 198.51.100.1
ip route 10.20.10.0 255.255.255.0 172.16.12.2
ip dhcp excluded-address 10.10.10.1 10.10.10.99
ip dhcp pool LAN-SIEGE
```

```
 network 10.10.10.0 255.255.255.0
 default-router 10.10.10.1
 dns-server 203.0.113.10
 domain-name camtrust.lab
username admin privilege 15 secret <MD5>
line vty 0 4
 login local
 transport input ssh
```

5.2. R-DLA — routeur MikroTik

```
/system identity set name=R-DLA
/ip address add address=172.16.12.2/30 interface=ether1
/ip address add address=10.20.10.1/24 interface=ether2
/ip route add dst-address=0.0.0.0/0 gateway=172.16.12.1
/ip pool add name=pool-dla ranges=10.20.10.100-10.20.10.200
/ip dhcp-server network add address=10.20.10.0/24 gateway=10.20.10.1 dns-server=203.0.113.10
domain=camtrust.lab
/ip dhcp-server add name=dhcp-dla interface=ether2 address-pool=pool-dla disabled=no
```

5.3. R-FAI — routeur VyOS

```
configure
set system host-name R-FAI
set interfaces ethernet eth0 address 198.51.100.1/30
set interfaces ethernet eth1 address 203.0.113.1/24
set protocols static route 10.0.0.0/8 next-hop 198.51.100.2
set protocols static route 172.16.0.0/12 next-hop 198.51.100.2
commit
save
exit
```